



Comprehensive Server Infrastructure Risk Assessment & Report

Last Updated : September 2026

Table Of Contents

1. Data Protection & Backup Strategy	1
1.1 Risk Identification & Vulnerability Matrix	1
1.2 Impact & Recovery	1
1.3 Mitigation & Implementation Strategy	2
2. Network & SSH Security	2
2.1 Risk Identification & Vulnerability Matrix	2
2.2 Impact & Recovery	3
2.3 Mitigation & Implementation Strategy	3
3. Monitoring & Uptime	3
3.1 Risk Identification & Vulnerability Matrix	4
3.2 Impact & Recovery	4
3.3 Mitigation & Implementation Strategy	4

Executive Summary

This comprehensive risk assessment and operational resilience report establishes a rigorous framework for securing self-hosted server infrastructure. Across the three core pillars of infrastructure management which are **Data Protection & Backup, Network & SSH Security, and Monitoring, Uptime & Power Resilience**. The report identifies critical exposure vectors, evaluates impact and recovery metrics, and outlines proactive engineering mitigations.



1. Data Protection & Backup Strategy

Data availability and integrity serve as the foundational pillars of any bare-metal infrastructure. Operating a self-hosted Debian server running CasaOS, Docker containers, and persistent storage volumes introduces significant vulnerability to single points of failure (SPOF). Without an automated and segregated backup pipeline, hardware degradation, catastrophic filesystem corruption, or administrator error carries a high probability of total data loss and prolonged service downtime.

1.1 Risk Identification & Vulnerability Matrix

1. Primary Boot Drive Single-Point-of-Failure (SPOF)

The system relies on a single dedicated boot drive for the Debian host OS and core system binaries. While operational, sudden hardware failure of the boot medium requires OS re-provisioning, mitigated entirely by the decoupling of persistent user data.

2. Storage Pool Redundancy via ZFS

Data integrity and high availability are enforced through a ZFS mirror pool configuration across secondary drives (for **sda** and **sdz**). This architectural split ensures that persistent Docker volumes, CasaOS states, and media assets remain resilient against individual hardware drive failures.

1.2 Impact & Recovery

1. Boot Drive Failure

Requires approximately 1 to 2 hours of manual intervention to re-provision a fresh Debian host, as system configuration backups and deployment manifests must be reconstructed from scratch.

2. Bounded by weekly ZFS snapshots

Any modifications to system states or uncommitted files made between the last snapshot cycle and a catastrophic failure carry a risk of permanent loss.

3. User data and container volumes are fully safeguarded against SPOF through ZFS mirroring. However, the single boot drive **remains a localized dependency** requiring a documented manual recovery playbook.



1.3 Mitigation & Implementation Strategy

1. Off-Server Configuration Replication

Implement automated synchronization (via rsync) of core configuration files (fstab, NetworkManager profiles) from the ZFS pool to a secondary network node to accelerate host re-provisioning.

2. ZFS Snapshot Maintenance

Retain and periodically verify scheduled weekly ZFS snapshots as the primary rollback mechanism for localized file corruption or accidental deletions.

3. Manual Recovery Documentation

Maintain a structured, offline deployment checklist detailing network bridge (br0) parameters and service mounting steps to minimize human error during an emergency OS rebuild.

2. Network & SSH Security

Exposing bare-metal server infrastructure to local networks or the public internet introduces constant vulnerability to brute-force attacks, unauthorized credential stuffing, and perimeter infiltration. Without enforced cryptographic access controls, proactive intrusion prevention, and secure virtual private networking, malicious actors can exploit default management ports or misconfigured service bindings to compromise host integrity.

2.1 Risk Identification & Vulnerability Matrix

1. SSH Brute-Force & Automated Bot Scans

Continuous automated scanning of standard administrative ports (e.g., port 22) by malicious crawlers attempting dictionary-based credential compromises.

2. Unencrypted Perimeter Exposure

Exposing raw management interfaces (such as CasaOS control panels or SSHdaemons) directly to untrusted external networks without encrypted tunnel isolation.

3. Delayed Incident Awareness

Lack of active, automated monitoring solutions resulting in prolonged latency before an administrator detects an ongoing intrusion or repetitive unauthorized access attempts.



2.2 Impact & Recovery

1. Immediate mitigation capabilities are handled automatically at the network layer via active intrusion prevention, reducing manual intervention time to zero during standard brute-force events. Full compromise recovery, however, would require complete host isolation, credential rotation, and system re-imaging.
2. Real-time monitoring ensures zero data loss latency regarding threat visibility; intrusion attempts and ban states are logged and reported instantly.
3. Reliance on default port configurations or unauthenticated management daemons creates a severe perimeter bottleneck.

2.3 Mitigation & Implementation Strategy

1. Tailscale Secure Mesh VPN

Restrict administrative access strictly through Tailscale encrypted wireguard tunnels, effectively removing direct public internet exposure for SSH and management portals.

2. Automated Intrusion Prevention (Fail2ban)

Deploy Fail2ban across active jails (such as sshd) to automatically ban malicious IP addresses after repeated authentication failures.

3. Real-Time Telegram Telemetry

Integrate a lightweight custom monitoring script that scans active Fail2ban jails and successful SSH logins, dispatching clean, structured status reports and instant block alerts directly to a secure Telegram channel.

3. Monitoring & Uptime

Infrastructure uptime relies heavily on environmental stability and proactive resource tracking. Operating bare-metal servers in a residential environment introduces significant vulnerability to sudden power grid fluctuations, lightning strikes, and recurring electrical trips. Uncontrolled sudden power loss risks severe filesystem corruption, database degradation, and permanent hardware wear. Furthermore, the absence of active performance monitoring leaves the host blind to abnormal resource consumption or failing background containers.



3.1 Risk Identification & Vulnerability Matrix

1. Residential Power Instability (Grid Failures)

Frequent household power trips and thunderstorm outages leading to abrupt ungraceful server shutdowns.

2. Hardware & Filesystem Corruptions

Sudden loss of power to ZFS pools or SSD storage controllers, risking data integrity loss or prolonged array resynchronization cycles.

3. Unmonitored Resource Exhaustion

Lack of continuous tracking for CPU, memory, and disk utilization via CasaOS dashboards or interactive utilities (htop), delaying detection of rogue runaway containers.

4. Lack of Centralized Telemetry

Absence of proactive uptime metrics, leaving administrators unaware of service degradations until total failure occurs.

3.2 Impact & Recovery

1. Extended during power events if improper shutdowns trigger lengthy ZFS pool consistency checks (*scrubs* or *imports*) or require physical hardware inspections.
2. Minimal risk of transactional data loss when power failures are met with controlled, automated emergency shutdowns driven by battery telemetry.
3. Direct dependency on raw residential AC power without autonomous backup and graceful shutdown signaling.

3.3 Mitigation & Implementation Strategy

1. CyberPower UPS Integration (pwrstat)

Deploy a hardware-backed uninterruptible power supply connected to the Debian host to maintain auxiliary power during electrical drops.

2. Automated Power-Event Telegram Script

Implement a custom lightweight Bash script managed by a systemd service that continuously queries pwrstat for live UPS metrics and immediately dispatches real-time Telegram alerts for power loss events.



Enquiries : faez@faezyahizan.xyz

3. Tiered Battery Warning & Graceful Shutdown Protocol

Configure automated notification thresholds for grid failure, a 50% capacity warning, and a 20% critical emergency shutdown sequence to preserve hardware health and data integrity.

4. Resource Health Tracking

Utilize native CasaOS monitoring dashboards and CLI diagnostics (htop) for ongoing observation of system resource allocation.